INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

RISK ASSESSMENT AND MANAGEMENT TECHNIQUES

WEEK 1 PRATICAL VULNERABILITY ASSESSMENT LAB

NAME	**ESTHER EGBAGBE**
REGISTRATION NUMBER	**C11/26/CGRCE/17574**
COHORT	**COHORT 11**
COURSE	**GRC103**
DATE SUBMITTED	**24th of October, 2026**
LAB Environment	**ICDFA Kali Linux VM(Attacker) and Metasploitable(Target)**
Tools	**Nmap, nikto, nucei, xsltproc**

The scans: ICDFA-Assignment/GRC103_Lab_Assignment at main · EgbagbeEsther/ICDFA-Assignment

Phase 1: Discovery and Enumeration

Step 1: Network Discovery

Task: Confirm the target is alive and identify its IP address

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:d3:52:20
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fed3:5220/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3 errors:0 dropped:0 overruns:0 frame:0
          TX packets:30 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1252 (1.2 KB)  TX bytes:3924 (3.8 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:96 errors:0 dropped:0 overruns:0 frame:0
          TX packets:96 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21437 (20.9 KB)  TX bytes:21437 (20.9 KB)

msfadmin@metasploitable:~$
```

Figure 1.1: Metasploitable target network Configuration showing IP 192.168.56.101

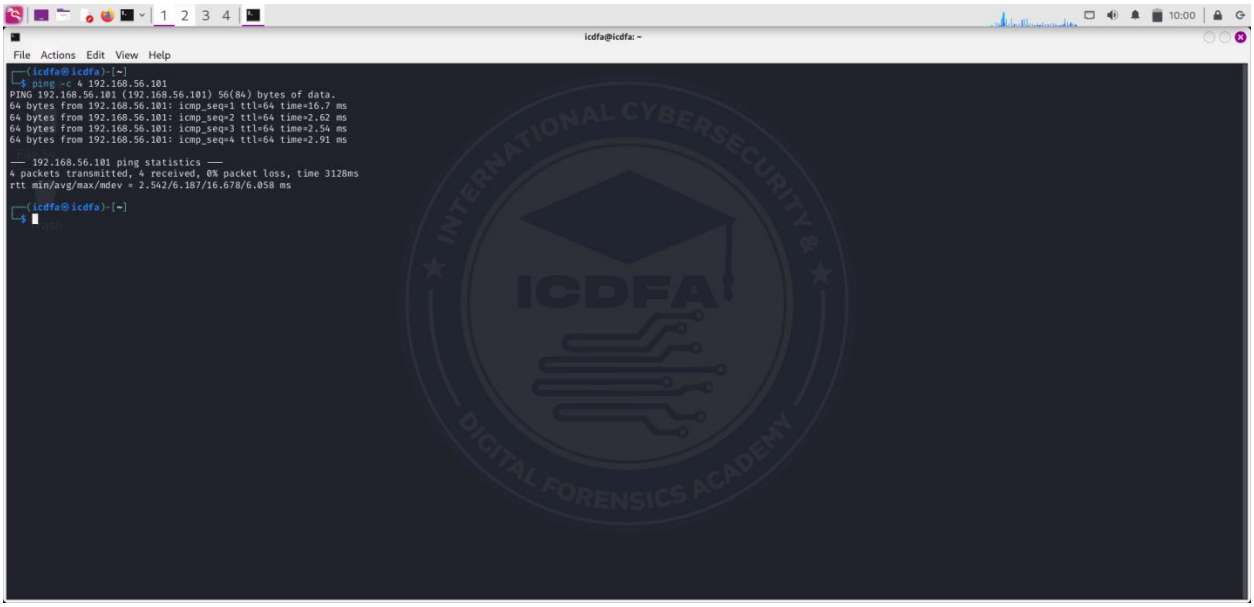


Figure 1.2: ping test confirming the metasploitable target is reachable from kali

Step 2: Port and Service Enumeration with Nmap

Task: Perform a comprehensive Scan to identify all open ports, servers, and versions

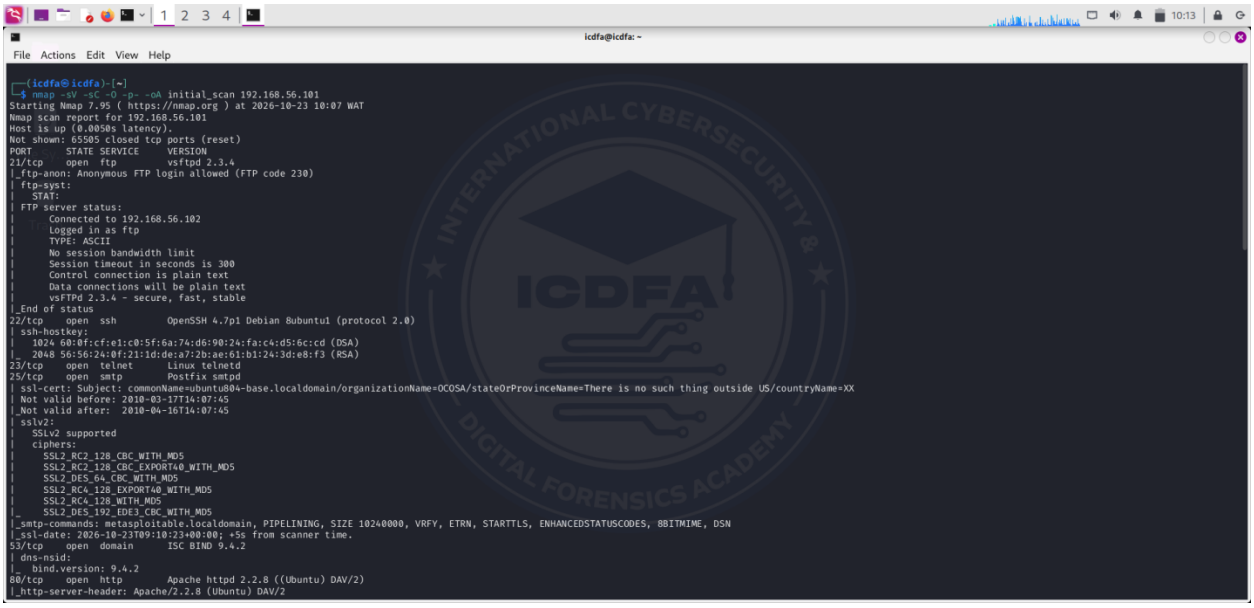


Figure 2.1a: Nmap_scan_ports_21-80

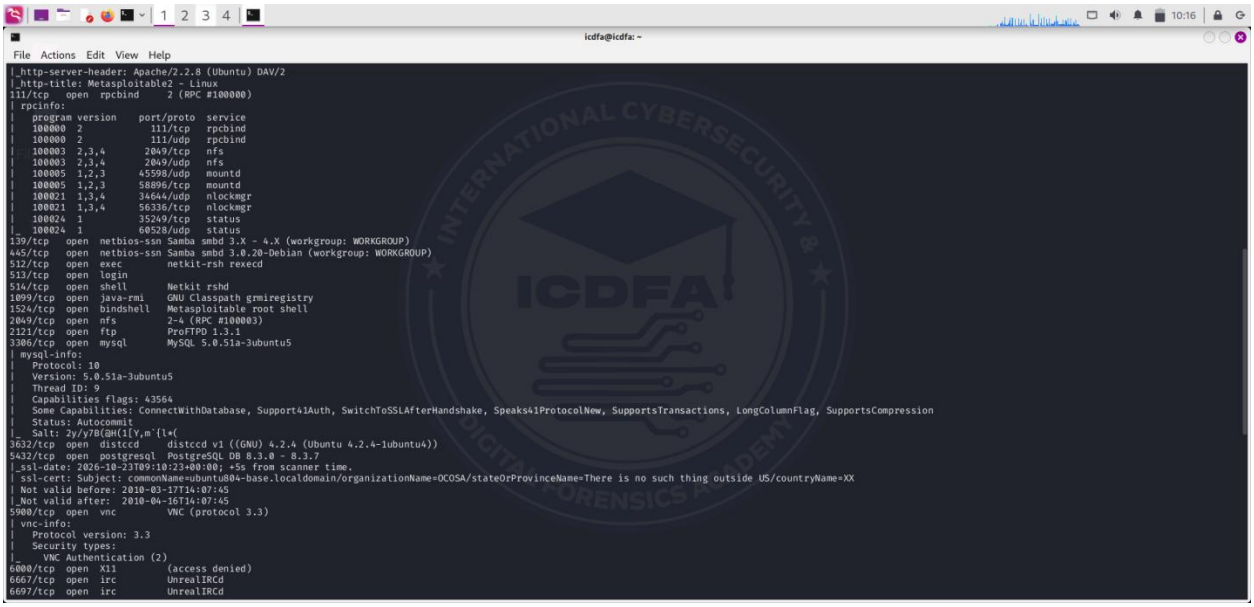


Figure 2.1a: Nmap_scan_ports_111-6697

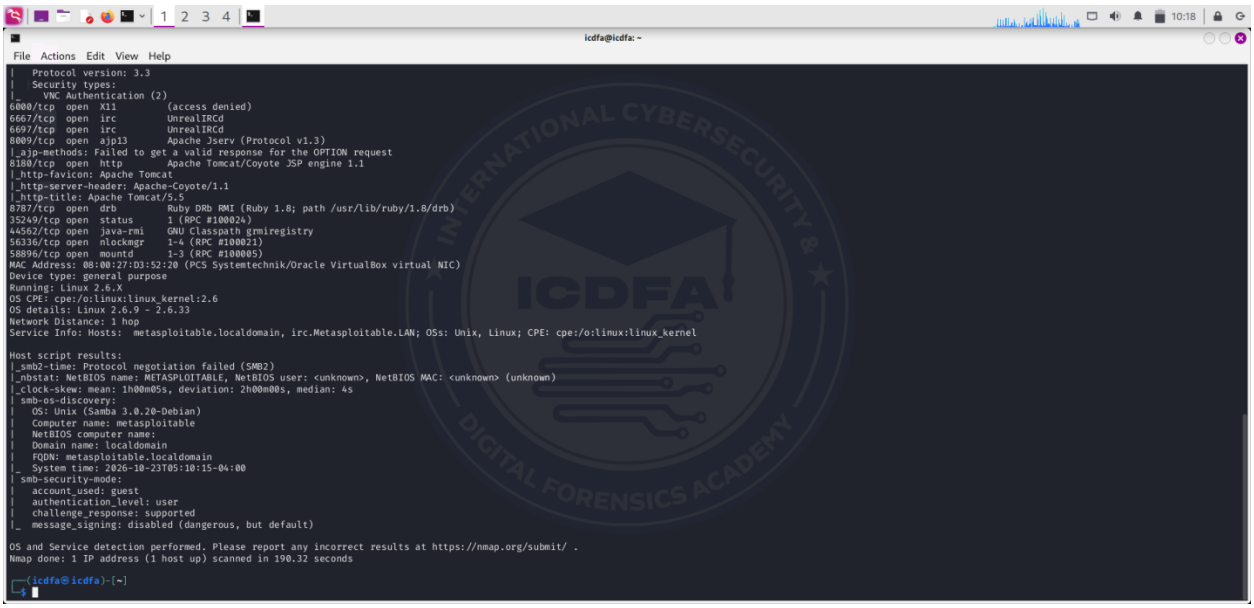


Figure 2.1c: Nmap_scan_summary

Nmap Scan of 192.168.56.101 Showing open ports, service versions and OS detection

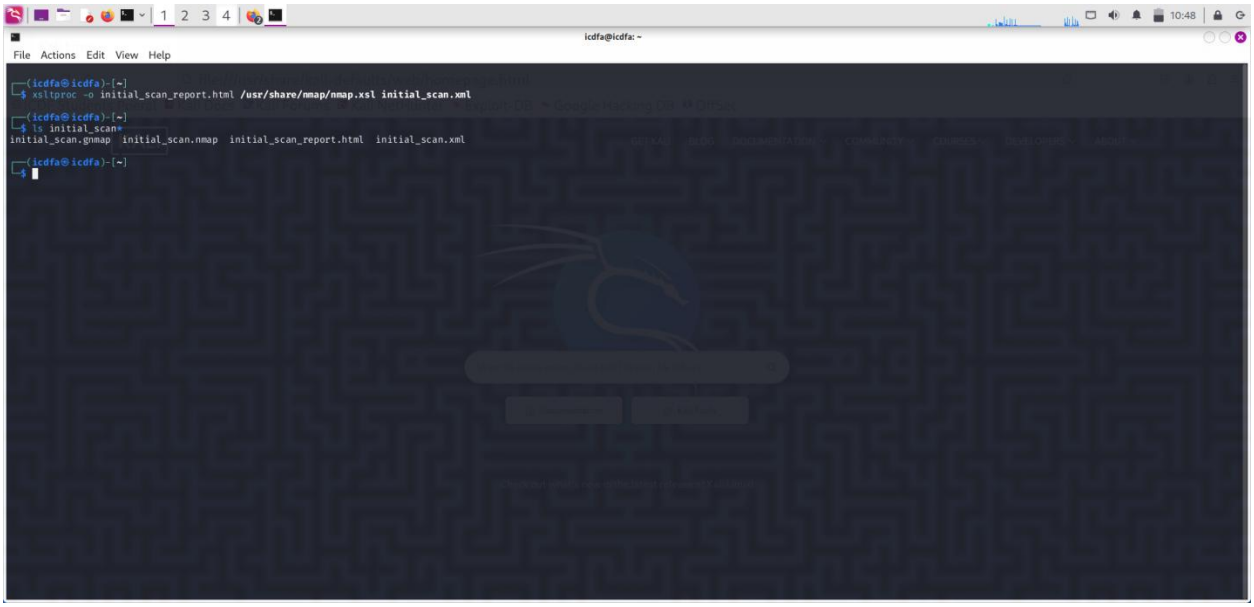


Figure 2.2: Nmap output files and HTML report generated from the Scan

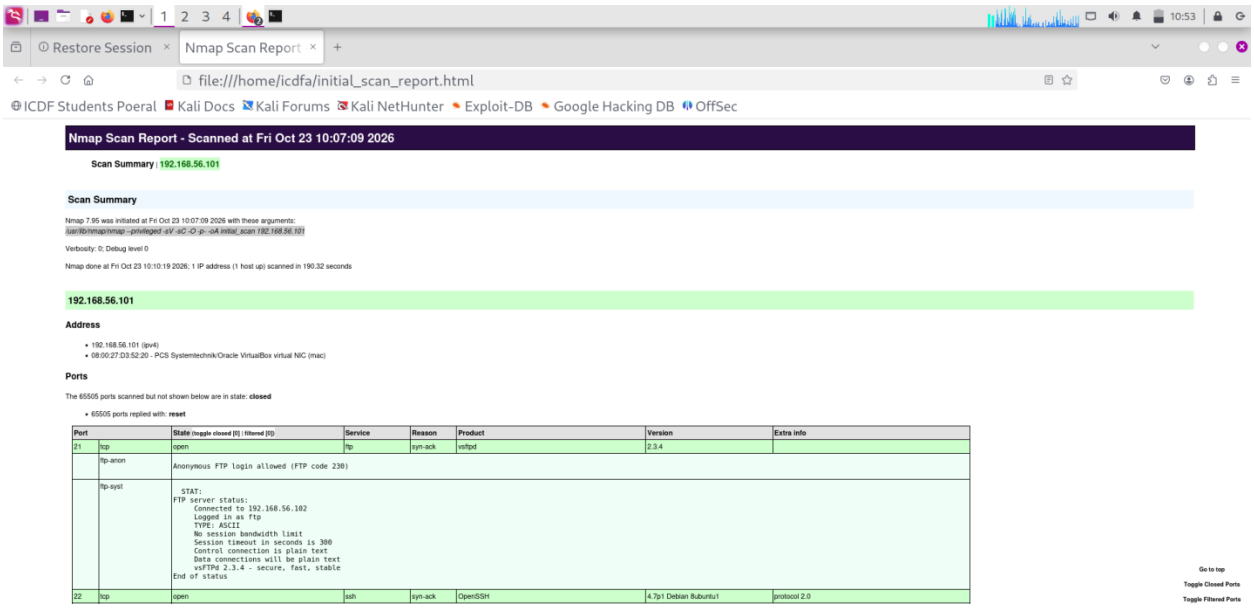
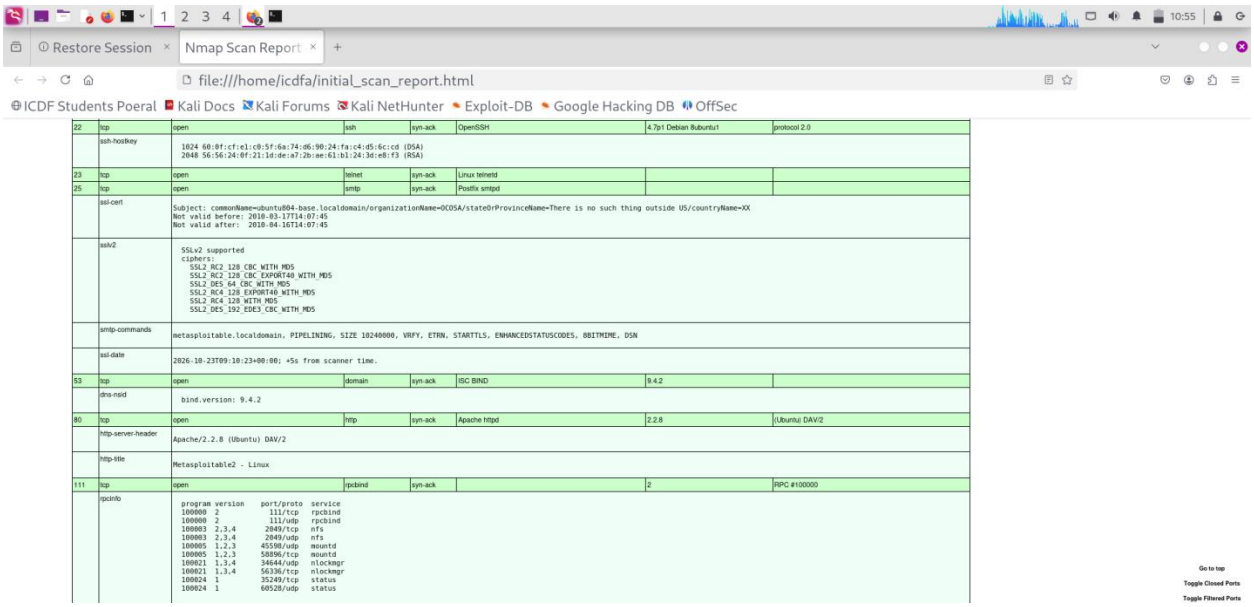
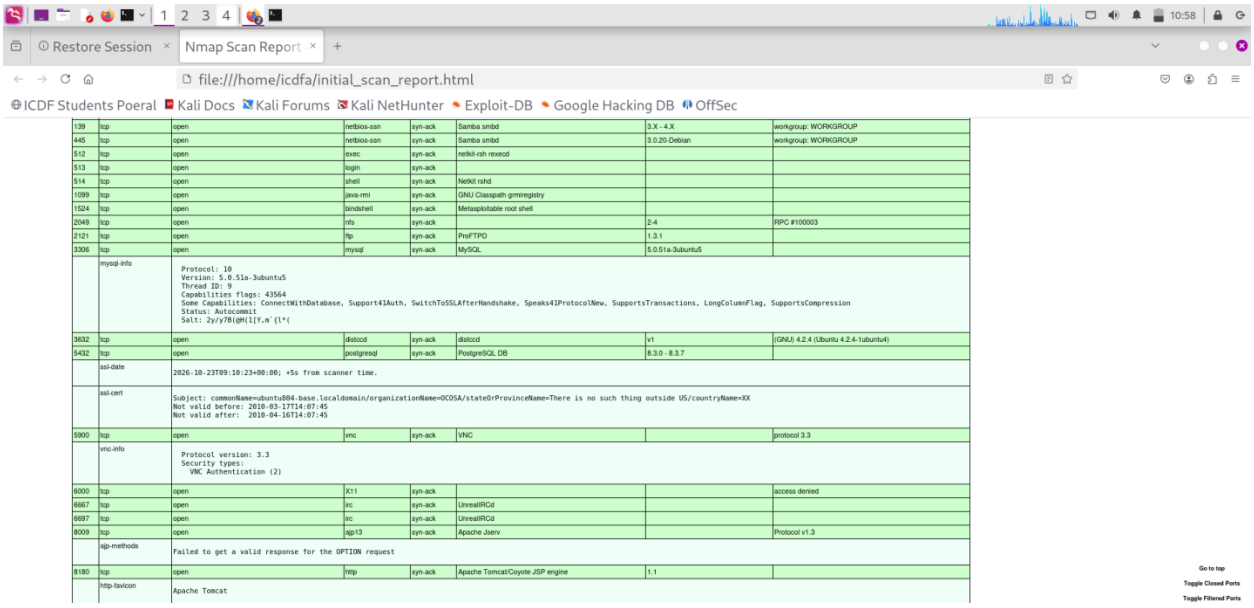


Figure 2.3a: Nmap_report_summary



22	tcp	open	ssh	syn-ack	OpenSSH	4.7p1 Debian 8ubuntu1	protocol 2.0
	ssh-hostkey	1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA) 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)					
23	tcp	open	telnet	syn-ack	Linux telnetd		
25	tcp	open	smtp	syn-ack	Postfix smtpd		
	ssl-cert	Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX Not valid before: 2010-03-17T14:07:45 Not valid after: 2010-04-16T14:07:45					
	sslv2	SSLv2 supported ciphers: SSL2_RC2_128_CBC_WITH_MD5 SSL2_RC2_128_CBC_EXPORT40_WITH_MD5 SSL2_DES_64_CBC_WITH_MD5 SSL2_RC4_128_EXPORT40_WITH_MD5 SSL2_RC4_128_WITH_MD5 SSL2_DES_192_EDE3_CBC_WITH_MD5					
	smtp-commands	metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN					
	ssl-date	2026-10-23T09:10:23+00:00; +5s from scanner time.					
53	tcp	open	domain	syn-ack	ISC BIND	9.4.2	
	dns-nsid	bind.version: 9.4.2					
80	tcp	open	http	syn-ack	Apache httpd	2.2.8	(Ubuntu) DAV/2
	http-server-header	Apache/2.2.8 (Ubuntu) DAV/2					
	http-title	Metasploitable2 - Linux					
111	tcp	open	rpcbind	syn-ack		2	RPC #100000
	rpcinfo	program version port/proto service 100000 2 111/tcp rpcbind 100000 2 111/udp rpcbind 100003 2,3,4 2049/tcp nfs 100003 2,3,4 2049/udp nfs 100005 1,2,3 45598/udp mountd 100005 1,2,3 58896/tcp mountd 100021 1,3,4 34644/udp nlockmgr 100021 1,3,4 56336/tcp nlockmgr 100024 1 35249/tcp status 100024 1 60528/udp status					

Figure 2.3b: Nmap_report_ports_22-111



139	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: WORKGROUP
445	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.0.20-Debian	workgroup: WORKGROUP
512	tcp	open	exec	syn-ack	netkit-rsh rexecd		
513	tcp	open	login	syn-ack			
514	tcp	open	shell	syn-ack	Netkit rshd		
1099	tcp	open	java-rmi	syn-ack	GNU Classpath grmiregistry		
1524	tcp	open	bindshell	syn-ack	Metasploitable root shell		
2049	tcp	open	nfs	syn-ack		2-4	RPC #100003
2121	tcp	open	ftp	syn-ack	ProFTPD	1.3.1	
3306	tcp	open	mysql	syn-ack	MySQL	5.0.51a-3ubuntu5	
	mysql-info	Protocol: 10 Version: 5.0.51a-3ubuntu5 Thread ID: 9 Capabilities flags: 43564 Some Capabilities: ConnectWithDatabase, Support41Auth, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, SupportsTransactions, LongColumnFlag, SupportsCompression Status: Autocommit Salt: 2y/y7B(@H{1[Y.m`{l*(					
3632	tcp	open	distccd	syn-ack	distccd	v1	(GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4)
5432	tcp	open	postgresql	syn-ack	PostgreSQL DB	8.3.0 - 8.3.7	
	ssl-date	2026-10-23T09:10:23+00:00; +5s from scanner time.					
	ssl-cert	Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX Not valid before: 2010-03-17T14:07:45 Not valid after: 2010-04-16T14:07:45					
5900	tcp	open	vnc	syn-ack	VNC		protocol 3.3
	vnc-info	Protocol version: 3.3 Security types: VNC Authentication (2)					
6000	tcp	open	X11	syn-ack			access denied
6667	tcp	open	irc	syn-ack	UnrealIRCd		
6697	tcp	open	irc	syn-ack	UnrealIRCd		
8009	tcp	open	ajp13	syn-ack	Apache Jserv		Protocol v1.3
	ajp-methods	Failed to get a valid response for the OPTION request					
8180	tcp	open	http	syn-ack	Apache Tomcat/Coyote JSP engine	1.1	
	http-favicon	Apache Tomcat					

Figure 2.3c: Nmap_report_ports_139-6697

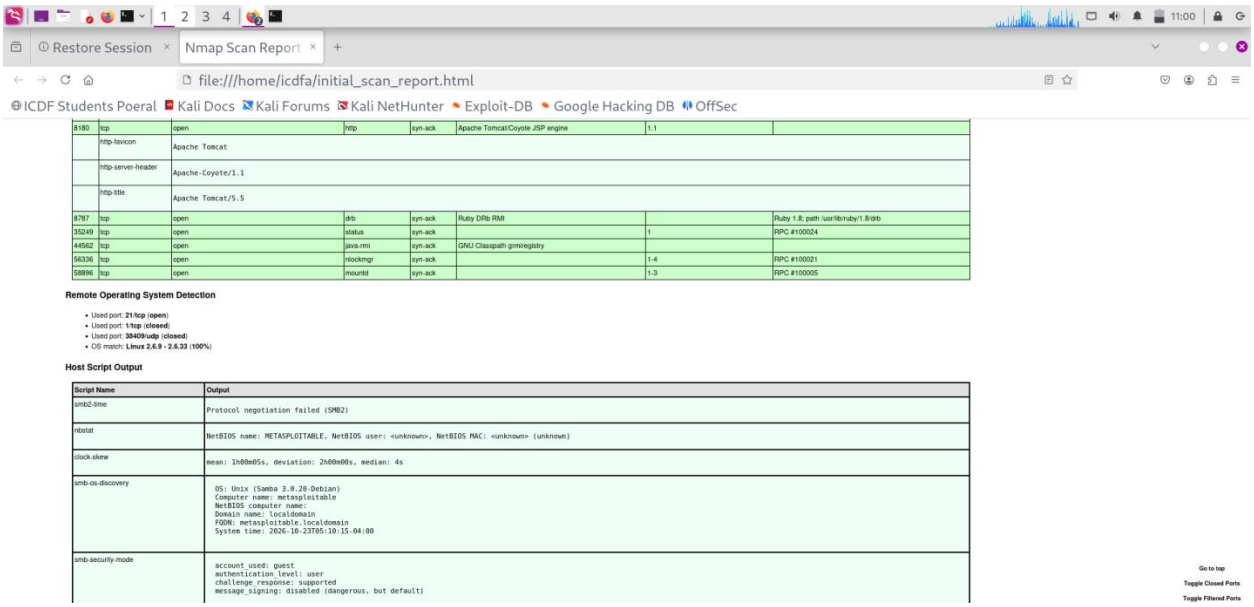


Figure 2.3d: Nmap_report_OS_and_Scripts

Figure 2.3 are Nmap HTML report for 192.168.56.101

GRC Question: Why is knowing which ports are open (e.g., 21/FTP, 23/Telnet) a compliance issue?

Every open port can create a way for attackers to get into a system. In this case, services like FTP (21), Telnet (23), and rlogin (513) were running on the server, even though the business doesn't need them. From a GRC perspective, we should only allow services that the business actually needs. This aligns with CIS Control 9 and NIST CSF PR.IP-1, which focus on secure configurations. Disabling unnecessary services also reduces the attack surface and gives attackers fewer ways to target the system.

Another issue is that FTP and Telnet send passwords in plain text, making it possible for someone on the network to intercept them. This goes against the protection of data in transit under NIST CSF PR.DS-2.

Lastly, we need to know what is running on our systems before we can properly protect them. This is where port scanning helps with asset inventory, which aligns with NIST CSF ID.AM-1 and CIS Control 1.

Phase 2: Vulnerability Identification

Step 3: Analyzing Nmap Output

Task: Review initial_scan.nmap and the HTML report

Port	Service/version	Why it matters
21	Vsftpd 2.3.4	Anonymous login allowed, plain text
22	OpenSSH 4.7pl	Very old version
23	Telnet	Plain text credentials
25	Postfix	SSLv2 + weak ciphers, certificate expired in 2010
80/8180	Apache 2.2.8 / Tomcat 5.5	Outdated web servers
139/445	Samba 3.0.20	SMB message signing disabled
512-514	Rexec, rlogin, rsh	Old remote access, no encryption
1524	Metasploitable root shell	A root shell open on the network
3306/5432	MySQL 5.0.51a / PostgreSQL 8.3	Database exposed
5900	VNC	Remote desktop exposed
6667	UnrealIRCd	Software known for a backdoor version

Step 4: Web Application Assessment

Task: Scan the web server for common vulnerabilities

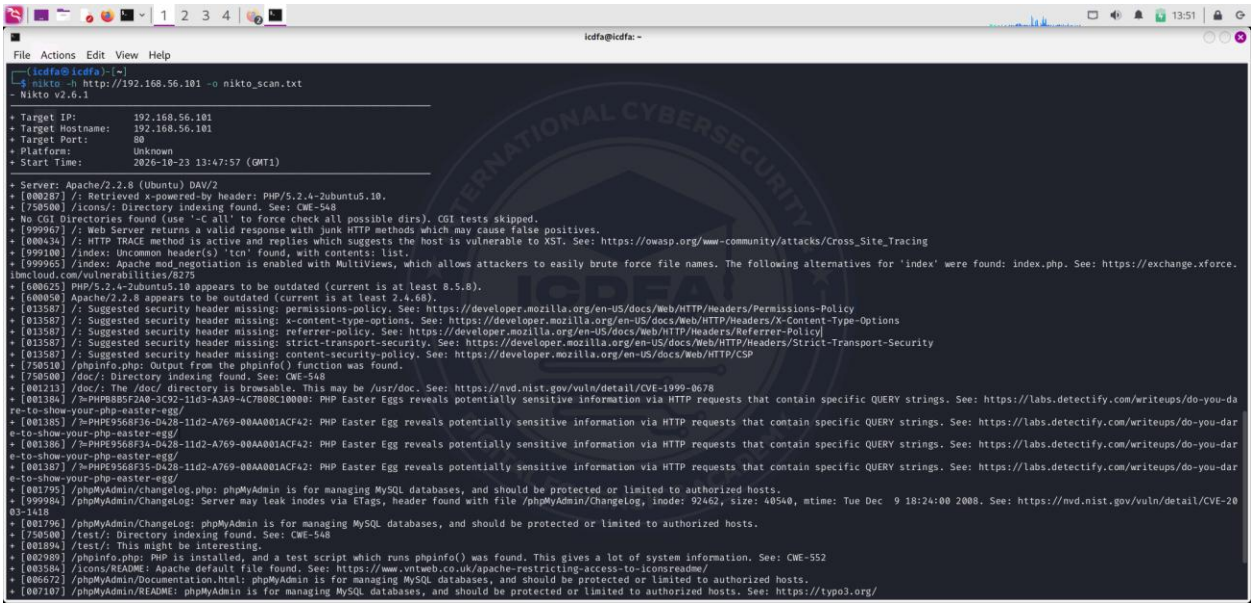


Figure 4.1a: nikto_scan_results



Figure 4.1b: nikto_scan_summary

Figure 4.1 are nikto web vulnerability scan of 192.168.56.101

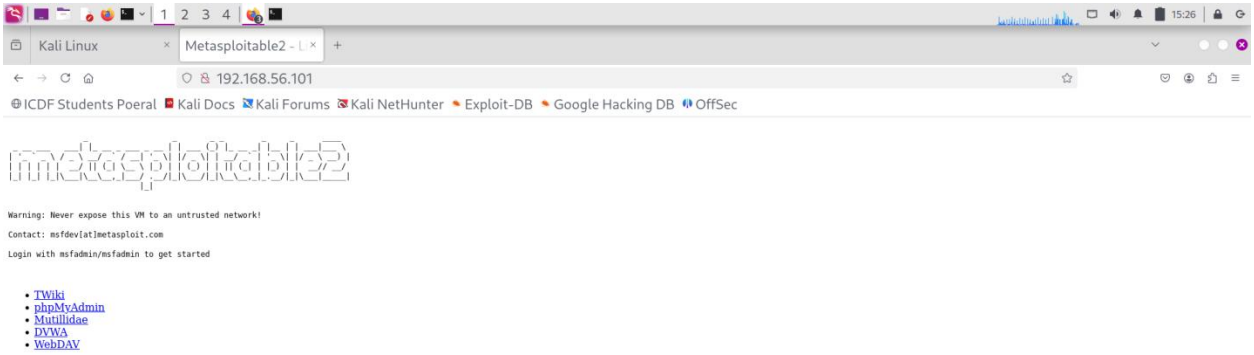


Figure 4.2: Metasploitable web server homepage at http://192.168.56.101 displaying default credentials

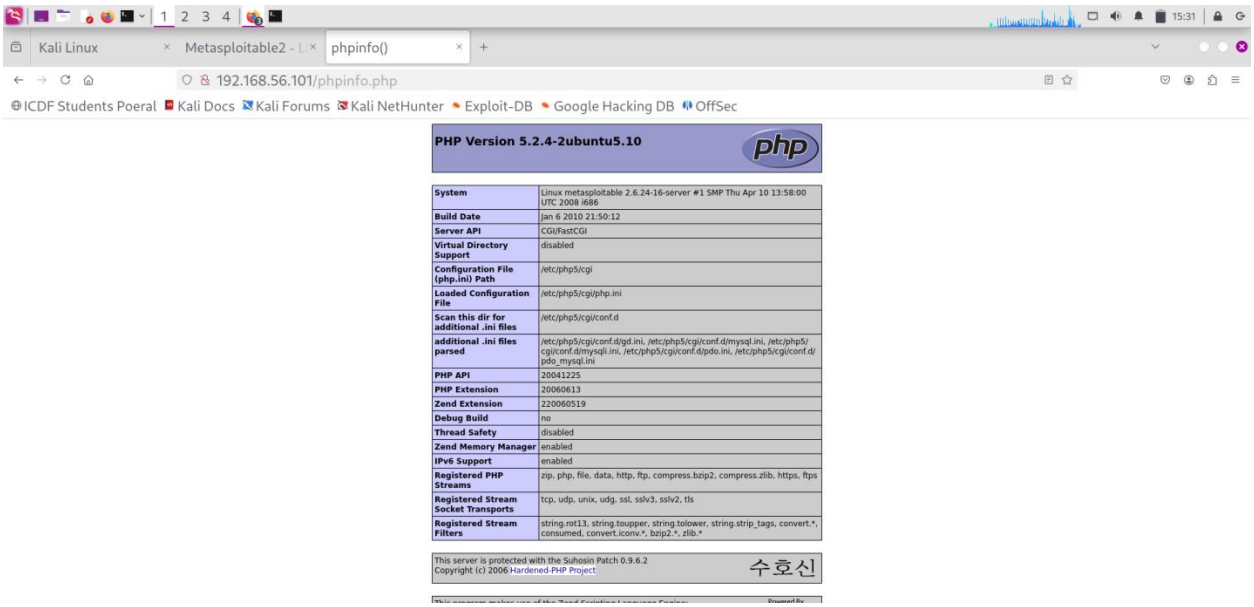


Figure 4.3: Exposed phpinfo page at /phpinfo.php disclosing PHP version, OS kernel and server configuration paths

Step 5: Focused Vulnerability

Task: Use Nuclei to scan for known vulnerabilities based on identified services

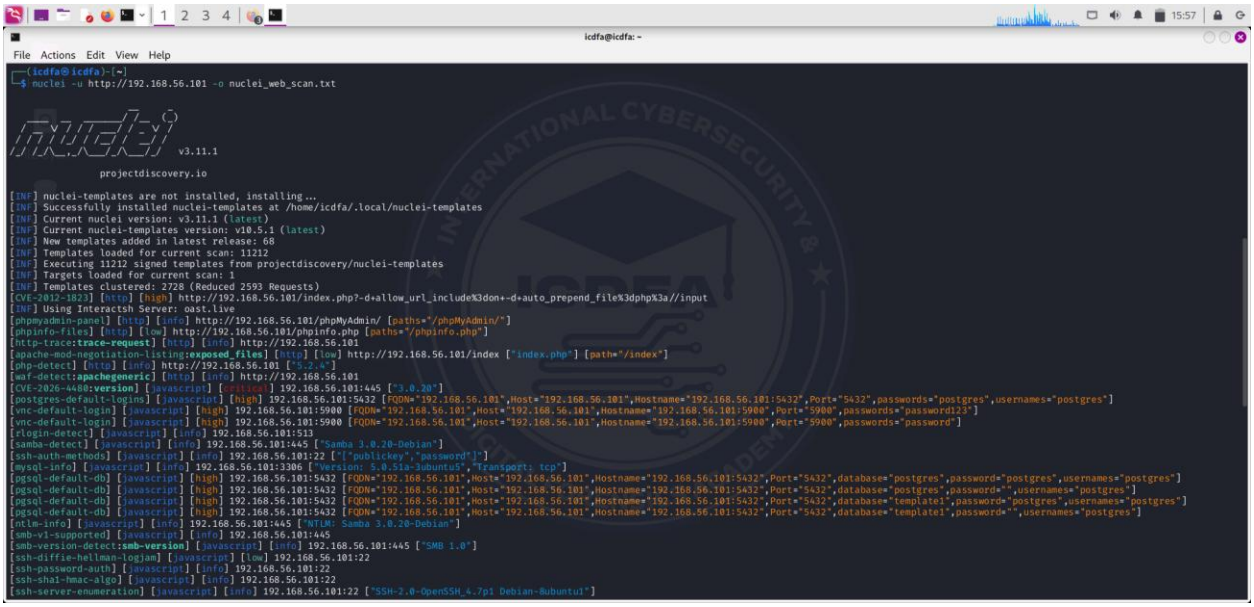


Figure 5.1a: Nuclei scan of 192.168.56.101

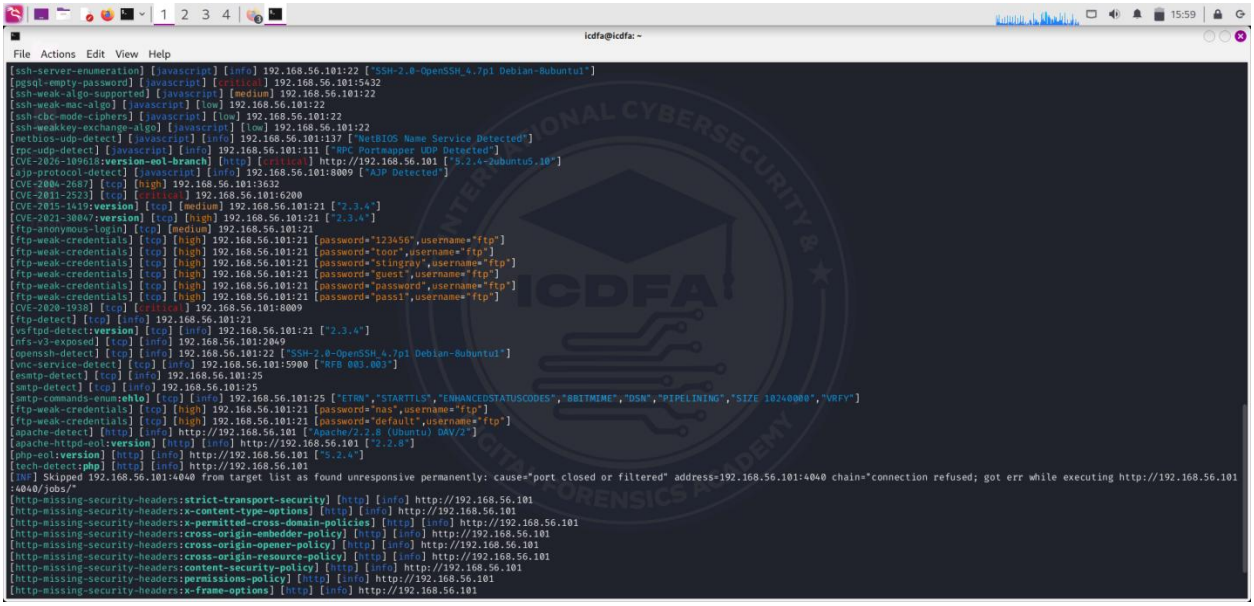


Figure 5.1b: Nuclei scan of 191.168.56.101



Figure 5.1c: Nuclei scan of 191.168.56.101

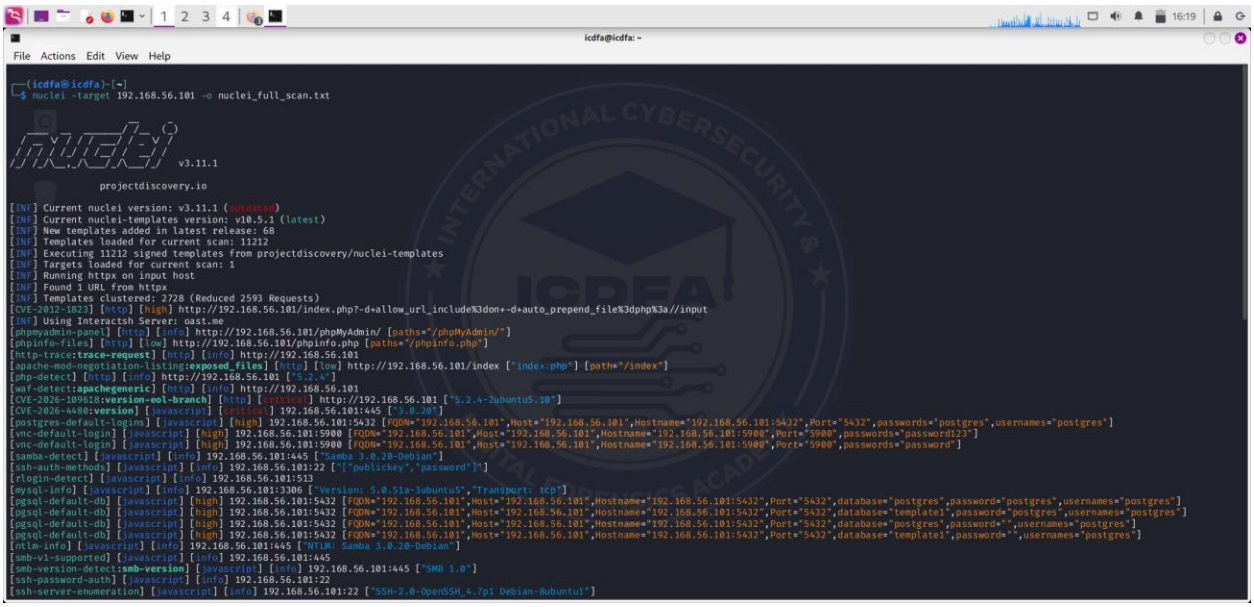


Figure 5.2a: Nuclei full-service scan of 192.168.56.101

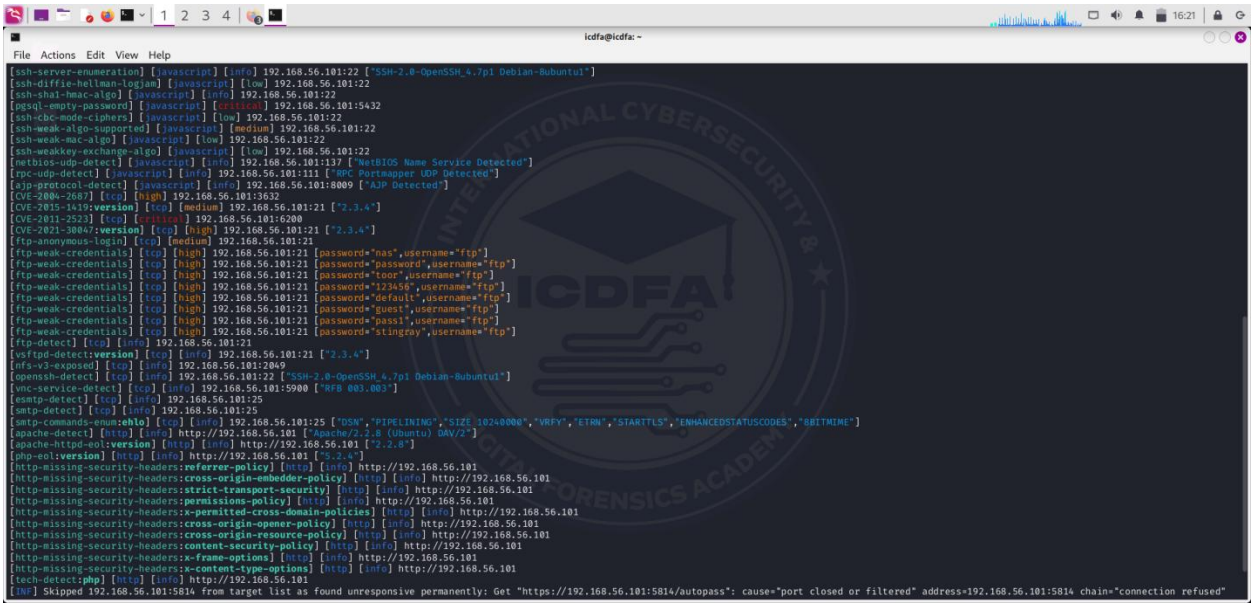


Figure 5.2b: Nuclei full-service scan of 192.168.56.101



Figure 5.2c: Nuclei full-service scan of 192.168.56.101

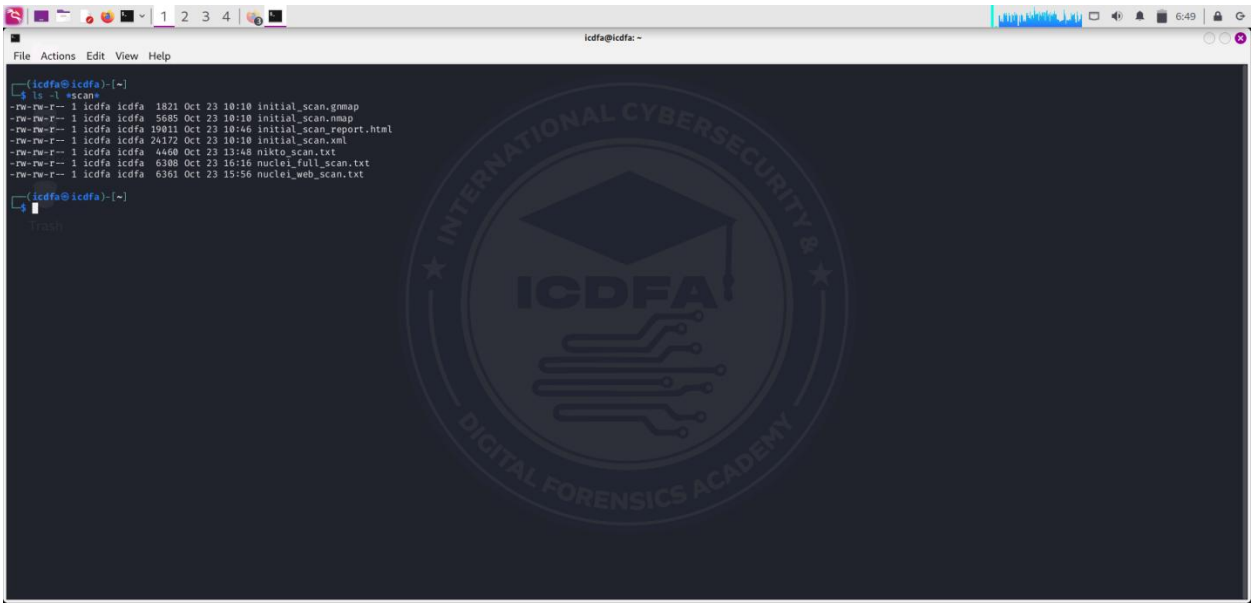


Figure 5.3: All scan output files generated during the assessment

Phase 3: Analysis and Reporting

Step 6: Triage and Risk Assessment

Risk Assessment Table summarizing key findings

Finding	Affected Service	CVE/Reference	Inherent Risk(L/M/H)	Compliance Violation	Business Impact
Weak Default Credentials	SSH,FTP	N/A	H	CIS 5.2, NIST CSF PR.AC-1	Unauthorized access, data theft
vsFTPd 2.3.4 Backdoor	FTP	CVE-2011-2523	H	CIS 7.1 9Patch Mgmt)	Full system compromise
Unencrypted Telnet Services	Telnet	N/A	H	NIST CSF PR.DS-2	Credential sniffing espionage
Open root Shell	Bindshll (524)	N/A	H	CIS 4.8 (disable unnecessary services), NIST CSF PR.PT-3)	Anyone on the network gets admin access instantly
Unencrypted remote access and file transfer	Telnet(23), FTP(21), rlogin/rsh/rexec (512-514)	N/A	H	NIST CSF PR.DS-2, CIS 3.10.PCIDSS 4.2.1	Credential sniffing espionage
Distccd remote command execution	Distccd (3632)	CVE-2004-2687	H	CIST 7.1 (Patch Mgmt), CIS 4.8)	Attacker can run commands on the server
Tomcat AJP flaw (“Ghostcat”)	AJP connector (8009)	CVE-2020-1938	H	CIST 7.1 (Patch Mgmt), PCIDSS 6.3.3)	Read of server files, possible code execution
PHP-CGI argument injection	Apache/PHP (80)	CVE-2012-1823	H	CIS 7.1 (Patch Mgmt), OWASP Top 10 A06)	Source code exposure, possible code execution
Outdated, unsupported software	Apache 2.2.8, PHP 5.2.4, OpenSSH 4.7pl, Samba 3.0.20, BIND 9.4.2, Linux 2.6 Kernel	CVE-2026-109618(PHP) and CVE-2026-4480(Samba), Flagged by nuclei from version numbers only	H	CIST 7.1 (Patch Mgmt), NIST CSF ID.RA-1, PCI DSS 6.3.3)	Known flaws, no more vendor patches, easy to attack
Anonymous FTP login allowed	FTP(21)	N/A	M	NIST CSF PR.AC-4,PR.AC-1	Anyone can read or upload files, data leakage

Databases reachable from the network	MySQL (3306), PostgreSQL(5432)	N/A	M	CIS 3.3 (secure configuration), NIST CSF PR.IP-1	Data theft or tampering
Weak SMB configuration	Samba(139/445)	N/A	M	NIST CSF PR.DS-2, PCI DSS 4.2.1	Traffic can be tampered with, malware can spread
Unnecessary services exposed	SMTP(25), PostgreSQL(5432), SSH(22)	N/A	M	OWASP Top10 A05, NIST CSF PR.AC-3	Database admin page open to the network
Admin tool exposed	phpMyAdmin (80)	N/A	M	OWASP Top10 A05, NIST CSF PR.AC-3	Database admin page open to the network
Information disclosure on web server	Phpinfo.php, directory listing (/ icons/,/doc/,/test/), HTTP TRACE	N/A	L	OWASP Top 10 A05, NIST CSF PR.IP-1	Gives attackers version and setup details
Missing HTTP security headers	Apache(80)	N/A	L	OWASP Top 10 A05, PCI DSS Req.6	Weaker browser protection against common web attacks

Step 7: Drafting the Executive Summary

To: IT Management

From: GRC Audit Team

Date: 24th October 2026

Subject: High-Risk Findings on Development Server ‘metasploitable’

1. Executive Summary

We checked the development server "metasploitable" for security weaknesses. It has serious problems that put the organization's information at immediate risk. Several of them would let an outsider take full control of the server without needing a password. The server also does not meet the security standards we follow (CIS Controls and NIST CSF). It should not be connected to any production or untrusted network.

2. Key Findings and Risks

- Critical Risk - Anyone can take over the server: Software on the server contains a hidden way in, and one door is left open to an administrator-level account. An attacker would not need a password. This breaks our rule on keeping software up to date (CIS 7.1).
- High Risk - Weak passwords: Easy to guess and factory default passwords are in use. The default login is even shown on the server's own web page. This makes unauthorized access easy (CIS 5.2).
- High Risk - Information sent in the open: Several services send passwords without protecting them, so anyone on the network could read them. This breaks our data protection standards (NIST CSF PR.DS-2).
- High Risk - Very old software: Most of the software on the server dates from around 2008, nearly two decades ago. Its makers no longer fix security problems in it, and attack methods for it are publicly known.
- Medium and Low Risk: Some management tools and settings are open to more people than they should be. The website also shares details about the server that an attacker could use.

3. Recommended Actions

- Immediate isolation: Disconnect the server from the network until it is fixed.
- Fix: Replace the unsafe software and update everything that is out of date.
- Tighten: Turn off services we do not use. Require strong, unique passwords and remove factory accounts. Make sure sensitive information is sent in protected form.
- Process review: Check every new server against a security checklist before it goes live. Scan regularly and keep an up-to-date list of all servers.
- Check: Test the server again after the fixes and keep the results as proof.